

MAINHEAD Workspace Grant Risk Audit

Live read-only audit against the connected database (localhost:5433/ascure) at 2026-06-03T14:27:34Z. Enumerates every user who currently receives INSPECTION or MAINTENANCE capability through a MAINHEAD-level assignment, and confirms whether the same capability is also granted via User / Team / Branch / Organization. Mirrors the resolution paths used by UsersService.getEffectiveCapabilitiesForUser. Assessment only — no application code modified.

VERDICT — No user in the current dataset would lose workspace access after Governance G2 deployment. Every affected user already receives the workspace capability from User AND Team AND Branch AND Organization sources, so the effective set survives the removal of the MAINHEAD contribution.

1. Audit at a glance

Metric	Value
MAINHEAD workspace assignments (MainheadCapability rows with code INSPECTION or MAINTENANCE, both isActive)	1
Affected MAINHEADs	1
Affected users (any access path to an affected MAINHEAD)	4
Distinct (user, MAINHEAD, capability) tuples	4
Users that would lose workspace access after G2	0

All MAINHEAD-level workspace assignments in the dataset are on a single MAINHEAD (SAVR MAINHEAD, code SAVR) and grant INSPECTION only. There are no MAINTENANCE assignments at the MAINHEAD level.

2. Affected users — full enumeration

The “Also from” columns answer the question “does this user have the same capability through an alternative source so that the workspace gate still resolves after MAINHEAD contributions are removed?”

User	MAINHEAD	Capability	Access via	User	Team	Branch	Org	Would lose?
ASCURE Admin admin@ascure.local Role: ADMIN	SAVR MAINHEAD (code SAVR)	INSPECTION	LEGACY, TEAM	Yes	Yes	Yes	Yes	No
Operations Manager manager@ascure.local Role: MANAGER	SAVR MAINHEAD (code SAVR)	INSPECTION	LEGACY, TEAM	Yes	Yes	Yes	Yes	No
Field Supervisor supervisor@ascure.local Role: SUPERVISOR	SAVR MAINHEAD (code SAVR)	INSPECTION	LEGACY, TEAM	Yes	Yes	Yes	Yes	No

User	MAINHEAD	Capability	Access via	User	Team	Branch	Org	Would lose?
Field Technician technician@ascure.local Role: TECHNICIAN	SAVR MAINHEAD (code SAVR)	INSPECTION	LEGACY, TEAM	Yes	Yes	Yes	Yes	No

3. Methodology

A throwaway Prisma script (deleted post-run, no application code modified) executed the read-only query below against the live DB. The script mirrors the five-source resolver in `UserService.getEffectiveCapabilitiesForUser`:

- Step 1 — Fetch every active `MainheadCapability` whose `Capability.code` is `INSPECTION` or `MAINTENANCE`.
- Step 2 — For each affected `MAINHEAD`, enumerate every user with access via the four `MAINHEAD`-access paths the resolver uses: (a) `UserMainheadAccess` (direct), (b) `UserOperationalRegionAccess` (region inheritance), (c) `teamMembership.team.mainheadId`, (d) legacy `user.mainheadId`.
- Step 3 — For each affected user, recompute the user's full scope sets (team / branch / org) using the same derivation chain as the resolver (team → branch / org; mainhead → branch; branch → organization).
- Step 4 — Look up `INSPECTION` / `MAINTENANCE` presence on User-direct, `TeamCapability`, `BranchCapability`, and `OrganizationCapabilityAssignment` rows for that user's scope sets.
- Step 5 — Mark “*would lose workspace access*” if the user is not `ADMIN` AND none of the four alternative sources also grants the same capability.

4. Per-user breakdown

Each affected user resolves the `INSPECTION` capability through every alternative source. Removing the `MAINHEAD` contribution is therefore a no-op for these users' effective sets and workspace access.

User	Why they are safe under G2
ASCURE Admin (ADMIN)	ADMIN role short-circuits the resolver — receives every active capability via scope: 'ADMIN' regardless of any per-source row. Also independently holds <code>INSPECTION</code> via User, Team, Branch, and Organization.
Operations Manager (MANAGER)	<code>INSPECTION</code> present via User + Team + Branch + Organization.
Field Supervisor (SUPERVISOR)	<code>INSPECTION</code> present via User + Team + Branch + Organization.
Field Technician (TECHNICIAN)	<code>INSPECTION</code> present via User + Team + Branch + Organization.

5. Pilot risk assessment

- **Current environment (dev):** zero users at risk. G2 may be deployed without any pre-deploy backfill.
- **This is the dev seed dataset.** Production may differ. Re-run the same query against staging and production before each promotion. Re-publishing the audit script for ops is recommended: it is short, idempotent, and read-only.
- **Same query also covers MAINTENANCE.** The dataset shows zero `MAINHEAD`-level `MAINTENANCE` assignments. Should production show any, they will appear in the same enumeration with the same “alternative source” checks.
- **Region access is in scope.** The query expands `UserOperationalRegionAccess` to every `MAINHEAD` in the region before checking workspace assignments. No region-inherited users were

found in the dev dataset.

- **Inactive rows are excluded.** The query filters all five capability tables and the user / mainhead / capability rows on `isActive: true`, matching the resolver's behaviour.

6. Re-run instructions for staging / production

To re-execute the same audit against another environment, point `DATABASE_URL` at the target DB and run the same Prisma audit script. The script is read-only and never writes. Suggested workflow:

```
$ DATABASE_URL='postgres:///...' \  
  npm exec tsx scripts/audit-mainhead-workspace-risk.ts
```

If `AUDIT_RESULT_JSON` shows any row with `wouldLoseWorkspaceAccess: true`, grant the same capability to the affected user at the User or Team level via the admin UI before deploying G2. After backfill, re-run the audit; the offending row should disappear.

7. Caveats

- **ADMIN visibility is a presentation choice.** The ADMIN row is listed for completeness; ADMINS cannot lose workspace access under G2 because the resolver short-circuits for ADMIN before reading any per-source row.
- **Active flags only.** Soft-deleted (`isActive=false`) users, mainheads, capabilities, and assignment rows are excluded — they don't contribute to authority today.
- **Audit script removed.** The temporary Prisma audit script was deleted after the run. No application code modified.
- **Re-audit before each promotion.** Production volumes are unknown to this report. The same query must run against staging and production before G2 is promoted there.